# この卒論を、最初から理解する

研究の目的と、全体の道順をつかむ。

**目的**

意図した通信かを
根拠付きで確認

**方法**

静的解析＋動的観測
＋意図との照合

**結果**

整合・不一致候補
確認・保留を区別

**中心の問い：自分のアプリの通信は、宣言した条件に合っているか。**

# 学ぶ順番： 8 つのまとまりで読む

分からない箇所へ戻れる地図を持つ。

| まとまり | 内容 | スライド |
| --- | --- | --- |
| 入口 | 研究の目的と読み方 | 1–2 |
| 基礎 | 通信・ APK ・静的と動的 | 3–7 |
| システム | 意図・観測・判定・証拠 | 8–18 |
| 研究設計 | RQ ・予想・実験群の区別 | 19–22 |
| 主評価 | 3 条件、 9 試行、方式比較 | 23–29 |
| 補助評価 | UDP ・失敗・ HTTPS ・公開アプリ | 30–37 |
| 解釈 | 不明・追跡・関連研究 | 38–40 |
| 結論 | 言えること・理解の確認 | 41–42 |

**先に用語、次に処理、最後に実験結果の意味を理解する。**

出典：本学習資料の構成（新しい研究結果ではない）

# なぜ「開発意図」を確かめたいのか

研究の動機を身近なアプリ開発と結び付ける。

**事前の想定**

入力したフィードだけ

**実装・依存**

コードやライブラリ

**確認したい差**

別の通信や宣言は?

**「何となく怪しい」ではなく、事前の条件と証拠で確認する。**

出典：卒論 §1.1–1.3

# 通信の基礎：宛先・ポート・方式

実験表に出てくる IP とポートを読めるようにする。

| 用語 | 例 | この研究での意味 |
| --- | --- | --- |
| IP | 10.0.2.2 | Emulator から Mac へ届く特別なアドレス |
| ポート | 18762 / 18761 | 同じホスト内の別の研究用窓口 |
| HTTP | GET /feed/... | 要求ヘッダーが平文で読める場合がある |
| TLS | 暗号化通信の仕組み | SNI だけでは本文・通信成功は分からない |

**同じ IP でもポートが違えば、許可条件が違う場合がある。**

出典：卒論 §3.5 ・ §4.5

# APK の基礎：アプリの箱を開ける

静的解析で調べるファイルを理解する。

### Manifest

権限・画面・通信設定
「宣言」を読む

### DEX

コード・文字列・ API 参照
「候補」を読む

### リソース

設定・文字列等
所在と一緒に保存

**APK に「含まれるもの」と、実行中に「使ったもの」は別。**

出典：卒論 §4.3 ・ §5.1

# 静的解析と動的観測は何が違うか

両方式が持つ情報と限界を比較する。

| 比較 | 静的解析 | 動的観測 |
| --- | --- | --- |
| アプリを起動 | 不要 | 必要 |
| 得る情報 | Manifest ・ URL ・ SDK 特徴 | 宛先・ UID ・時刻・方式 |
| 見落とす要因 | 実行時生成・難読化など | 未操作・窓外・取得制約 |
| 結果の意味 | 使う可能性がある候補 | この条件で観測した記録 |

**静的＝宣言と候補。動的＝今回の操作中の観測。**

出典：卒論 §1.2 ・ §9.3

# 入力は 3 つ：意図・ APK ・シナリオ

判断基準と、試した操作を分ける。

**意図 JSON**

判断の基準

**APK**

解析するアプリ

**シナリオ JSON**

実行する操作と時間

**「許すこと」と「今回試すこと」は、別々に記録する。**

出典：卒論 §3.1 ・ §5.4 ・ §6.2

# 意図 JSON を日本語に読み替える

実際の主評価の条件を理解する。

| 欄 | 設定 | 読み方 |
| --- | --- | --- |
| network | 登録入力先＋固定許可先 | 固定許可先は空。記録された入力を使う |
| permissions | INTERNET のみ | 位置権限等は許可集合に含まない |
| sdk | deny_all | 登録ルールで一致する SDK 候補を比較 |
| 平文・ Home 後 | allow / forbid | 方式や操作区間も別規則で比較 |

**主評価の基準：記録された入力先だけを、証拠条件付きで許す。**

出典：卒論 §5.2 ・ examples/intent-recorded-input-v1.1.json

# 出力は 4 種類。何が違うのか

レポートの判定を読む。

| 判定 | 意味 | 短い例 |
| --- | --- | --- |
| 整合 | 比較できた条件を満たす | 登録入力先への対象 HTTP 要求 |
| 不一致候補 | 明示条件の外にある | 許可外ポートへの対象要求 |
| 要確認 | 条件未指定や候補の確認 | 使われたか不明な URL 文字列 |
| 判定不能 | 判断に必要な根拠が不足 | UID 不明・対象未観測 |

**判定だけでなく、観測・帰属・取得状態も一緒に読む。**

出典：卒論 §3.3–3.4 ・ §4.6

# 全体構成：入力からレポートまで

処理の順番と担当をつかむ。

**入力・保存**

意図／ APK ／操作

**証拠取得**

静的＋ Android 通信

**正規化・照合**

UID ／時刻／条件

**説明・出力**

HTML ／ JSON ／
証拠 ID

**自作の中心：証拠をそろえ、意図と照合し、根拠を示す。**

出典：卒論 図 1 ・第 4 章

# 静的側：何をどこから取り出すか

静的出力が根拠になる理由を理解する。

### 宣言

権限・通信設定
実際の使用とは別

### コードの候補

URL ・ API 参照
実行事実とは別

### SDK 候補

4 種の登録特徴
送信主体とは別

**宣言と候補を抽出し、元の所在へ戻れるようにする。**

出典：卒論 §4.3 ・ §5.1 ・ §5.5

# 動的側：前後の対照も取得する

自動実験の手順と対照の意味を理解する。

**準備**

APK hash ・ UID

**前対照**

開始・ HTTP 確認

**操作**

起動・ URI ・待機

**後対照・停止**

回収・記録確認

**対照が通ることと、全通信の完全取得は別の確認。**

出典：卒論 §4.4 ・ §7.1

# UID： この通信は誰のものか

宛先だけで対象アプリへ帰属させない理由を学ぶ。

| 記録 | 区分 | 比較への使い方 |
| --- | --- | --- |
| 対象 UID と一致 | target | 宛先条件を評価できる |
| 別 UID | other | 対象アプリの違反としない |
| UID 欠落・矛盾 | unknown | 対象の判定を保留する |
| 拡張 PCAP | 全パケットの UID 一致 | 欠落・不一致があれば不明 |

**UID 不明は「誰が送ったか不明」であり、無通信とは違う。**

出典：卒論 §3.6 ・ §4.5

# 時計：いつ起きた通信なのか

時刻補正と境界での保留を理解する。

| 用途 | 時刻の条件 | 意味 |
| --- | --- | --- |
| 基本の補正 | ホスト時刻＝端末時刻＋差 | 同じ基準へそろえる |
| 操作・ Home 対応 | 開始時刻の誤差幅が内側 | 操作上の時間関係 |
| 入力先の例外 | フロー全体＋誤差幅が内側 | 登録操作の範囲で許可を比較 |
| 境界に重なる | boundary uncertain | 推測で区間へ入れない |

**時刻の「点」だけでなく、誤差を含む「幅」で比較する。**

# 記録の単位：パケットと指摘は違う

結果の数字を足し間違えない。

| 単位 | 例 | 足し方の注意 |
| --- | --- | --- |
| 端末試行 | シナリオを 1 回実行 | 再解析で増やさない |
| フロー / 要求 | RSS006： 2 / 3 | 同じ単位ではない |
| 宛先 | RSS006： 1 研究用端点 | フロー数と一致しない |
| 指摘 | C02 ・ C05 ・ C06 | 1 通信に複数付き得る |

**試行・ APK ・パケット・フロー・要求・指摘を別々に数える。**

出典：卒論 §6.4 ・ §8.4 、 RSS006 の補助点検

# 「静的のみ」「動的のみ」の読み方

差分の分類と意図の判定を区別する。

| 対応分類 | 分かること | まだ分からないこと |
| --- | --- | --- |
| 両方に対応 | 候補と観測端点が合う | 送信コード箇所や目的 |
| 静的候補のみ | 対応する観測がない | 未使用か、未操作か |
| 動的のみ | 候補に対応しない対象観測 | 入力・設定・生成などの原因 |
| 対応不明 | 帰属・ホスト・取得等が不足 | 存在・不存在・違反 |

**差分は「どちらの証拠に現れたか」。意図照合は「条件に合うか」。**

出典：卒論 §3.10 ・ §8.4 ・ §9.2

# 照合規則：どの問いを評価するか

C01 〜 C07 が担当する問いを理解する。

| 規則 | 問い | 根拠 |
| --- | --- | --- |
| C01 / C02 | 禁止・許可先と合うか | 対象の試行・宛先・方式 |
| C03 / C04 | SDK 候補・権限宣言と合うか | APK の静的情報 |
| C05 | 平文条件と合うか | 設定と観測を別評価 |
| C06 | Home 後条件と合うか | 成功した操作区間 |
| C07 | 何が不足・未指定か | 取得・帰属・候補・範囲 |

**複数規則の結果を残し、１つの危険度へ押しつぶさない。**

出典：卒論 表：照合の基本規則・ §3.3

# 入力先なら、何でも許可するのか

登録入力先の例外が証拠に依存することを学ぶ。

**登録記録**

成功した URI 操作

**対象の証拠**

UID ・ TCP ・端点

**比較条件**

方式・時刻区間

**出力**

整合／不足／不一致

**入力先の許可は、登録操作と観測の対応が確認できた範囲だけ。**

出典：卒論 §5.2 ・ intent_extensions.py

# 研究課題：実験で答えたい 3 つの問い

RQ と実験結果の対応を理解する。

| RQ | 確かめたいこと | 主な根拠 |
|---|---|---|
| RQ1 | 許可外の候補を示せるか | fixed 3 試行＋別の権限素材 |
| RQ2 | 整合と保留を分けられるか | input 3 試行＋ delayed 3 試行 |
| RQ3 | 根拠追跡と再現ができるか | 9 原本の再解析・証拠索引 |

**RQ ごとに、どの結果が答えになるかを対応付ける。**

出典：卒論 §6.1 ・ §9.1

# 主評価の「予想」をやさしく言うと

期待出力と研究仮説の違いを理解する。

### 予想① 入力先

許可した要求
→ 整合

### 予想② 固定先

許可条件の外
→ 不一致候補

### 予想③ 窓の外

対象要求が未観測
→ 判定を保留

**主評価の 3 予想は、参照素材に対する規則動作の期待。**

出典：卒論 §6.2 ・ §7.1（本スライドの言い換えは学習用）

# 実験全体の地図：何を何件行ったか

主評価・補助・開発確認の役割を区別する。

| 区分 | 件数・単位 | 何のためか |
|---|---|---|
| 主評価 | 9 端末試行 | 事前意図の 3 条件の動作確認 |
| 補助評価 | 29 端末試行 | 取得・帰属・公開アプリの補助例 |
| 方式比較 | 27 再解析出力 | 同じ 9 原本を 3 方式で処理 |
| 開発用確認 | 10 素材・ 103 項目／ 333 検査 | 実装の回帰確認。一般精度ではない |

**9 ＝主評価、 29 ＝補助、 27 ＝再解析出力。精度の分母へ一括合算しない。**

出典：卒論 §6.2・付録 A–B

# 主評価の共通条件をそろえる

何を固定して、何を変えたかを確認する。

| 固定・記録したもの | 内容 |
| --- | --- |
| Android / 収集器 | API35 ・ arm64 、 PCAPdroid 2.0.2 |
| 操作・時間 | 起動 5 秒 → URI 入力後 30 秒 |
| 意図 | 登録入力先だけを許可 |
| 入力ポート / 固定ポート | A=18762 、 B=18763 ／ 18761 |
| 実行者・状態 | 著者本人。追加操作なしの終了後申告 |

**同じホストのポート違いを使う、制御された自作素材の評価。**

出典：卒論 §7.1・付録 A

# 条件①：入力した先に接続する

input 素材の操作と期待を追う。

**入力 A / B / A**

A： 18762
B： 18763
A： 18762

**対象アプリ**

入力先へ HTTP 要求

**照合**

端点・ UID ・方式・区間

**結果**

整合 3/3

**入力と観測が対応し、 3 試行とも意図の範囲で整合。**

出典：卒論 §7.2 ・ trial-results.csv input-*

# 条件②：別の固定先へ接続する

fixed 素材で何を指摘したかを理解する。

**入力 A / B / A**

A： 18762
B： 18763
A： 18762

**対象アプリ**

常に 18761 へ HTTP 要求

**意図との比較**

許可した端点の外

**結果**

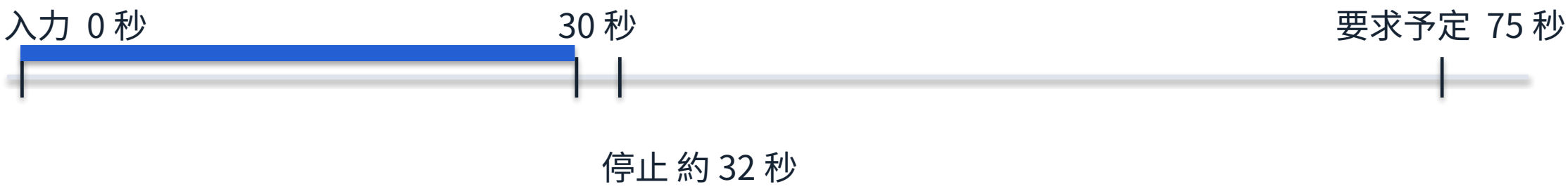
不一致候補 3/3

**入力先と別の固定ポートへの対象要求を、 3/3 で不一致候補にした。**

出典：卒論 §7.2 ・ trial-results.csv fixed-*

# 条件③：要求予定は 75 秒後、窓は 30 秒

遅延素材で確認した「保留」の意味を理解する。




**この窓では対象要求 0**

予定時刻へ到達する前に停止
→ 無通信とは結論しない

**確認したのは遅延送信の検出ではなく、対象未観測の保留。**

# 主評価の結果を 1 枚で読む

目的・証拠・主要出力をまとめる。

| 条件（各 3 ） | 対象 HTTP 要求 | 主要出力 | 結果 |
| --- | --- | --- | --- |
| 入力先 | 各 1 件 | 整合 | 3/3 |
| 許可外固定先 | 各 1 件 | 不一致候補 | 3/3 |
| 窓外の予定 | 0 件 | 判定不能・未観測 | 3/3 |

**設計した 3 つの出力が、参照条件で期待どおり動作した。**

出典：卒論 表：規則の動作確認 9 試行・ review.json

# 実例： fixed-001 の指摘をたどる

抽象的な規則を実際の記録へ結び付ける。

**入力と観測**

入力 18762
実測 18761

**指摘**

F00006 / C02

**証拠 ID**

capture-1-flow-4

**元パケット**

パケット 15–24
GET は 18 番

**指摘 → 証拠 ID → 原本位置の順に、判断の材料へ戻れる。**

# 静的のみ・動的のみ・併用を比べる

方式比較が示したことを正確に読む。

| 方式 | 通信に関する証拠 | 主な出力 |
| --- | --- | --- |
| 静的のみ | 実測を除外、 URL 候補 0 | 通信評価の不足を明示 |
| 動的のみ | 同じ 9 原本と共通の操作条件 | 整合 3 ・不一致 3 ・保留 3 |
| 併用 | 静的結果＋同じ動的証拠 | 主要通信判定は動的のみと一致 |

**今回の主通信判定は、動的のみと併用で同じだった。**

出典：卒論 §7.3 ・ component-analysis.json

# 静的な補助確認：権限だけある素材

宣言だけでも点検できる例と、開発確認を理解する。

### 権限素材

位置権限の宣言
C04 不一致候補

### 今回の事実

位置 API ・通信 API は未使用
静的な別素材

### 開発用検査

10 素材・ 103 項目
自動検査 333 件

**権限の宣言は静的に確認できる。実使用や送信とは別の成果。**

# 補助群の入口：制御 19 試行

初期の通信実験が何に役立ったかを把握する。

| 条件 | 試行数 | 対象記録あり | 不明候補あり |
|---|---|---|---|
| HTTP | 4 | 4 | 0 |
| 通信なし条件 | 1 | 0 | 0 |
| 短時間 UDP | 4 | 0 | 4 |
| 保持 UDP | 4 | 4 | 0 |
| HTTP 処理不成功 | 3 | 3 | 0 |
| 専用信頼 HTTPS | 3 | 3 | 0 |

**制御 19 試行は、取得・帰属・観測の意味を確認する補助群。**

出典：卒論 付録 B 表：補助 29 試行

# UDP： 記録はあるが、名前が Unknown

不明の保持を支えた実例を理解する。

| 条件 | 保存された記録 | 解釈 |
| --- | --- | --- |
| 短時間 UDP 4 | UID 不明候補あり | 対象の違反・無通信へ変換しない |
| 保持 UDP 4 | 対象記録あり | この条件の記録として報告 |
| 両群の差 | 版・本文長・日付も相違 | 保持時間だけの効果とはしない |

**記録の有無と、対象アプリへ割り当てられるかは別の問題。**

出典：卒論 §6.3 ・ §8.5 ・ §9.4

# 失敗通信と HTTPS： 何を確認したか

接続結果と取得結果、信頼設定の範囲を区別する。

### HTTP 処理不成功

3 試行：接続試行＋ SocketTimeoutException

### 専用信頼 HTTPS

3 試行：専用 APK とアプリ・サーバー記録

### 範囲の区別

CSV 表示だけで成立へ昇格しない
一般 HTTPS 本文の復号は別

**通信の成功・失敗と、取得の成功・不足を混同しない。**

# 「通信なし」と「起動だけ」は別条件

ゼロ件の意味を条件とともに読む。

| 試行 | 対象記録 | 評価した範囲 |
| --- | --- | --- |
| 通信なし制御 1 | 0 | 指定した通信なし素材と観測窓 |
| 公開アプリ起動 1 | 0 | 起動・待機の指定操作 |
| 静的候補あり＋動的 0 | 両立する | 未操作機能や取得制約は残る |

**ゼロは「その窓での対象未観測」。アプリ全体の無通信ではない。**

出典：卒論 §6.2 ・ §8.4 ・付録 B

# 公開アプリ： RSS 操作で何が見えたか

実行時入力と開始状態の影響を理解する。

| 試行 | 追加操作・開始状態 | 読み方 |
| --- | --- | --- |
| RSS001 | 購読・再生等あり | 混合操作の事例 |
| RSS002 / 003 | 追加操作なし申告、開始前なし | 状態を同一とはみなさない |
| RSS006 | 前画面あり、既存購読あり | 対象 2 フロー・ 3 要求・ 1 宛先 |

**追加操作・既存購読・要求数を保存し、試行差を単一原因にしない。**

出典：卒論 §6.5 ・ §8.4 、 RSS006 補助点検

# 静的文脈： 29 箇所のうち 2 が定数

限定した引数追跡で何が分かったかを読む。

### 解析した箇所

対応 4 API
29 引数箇所

### 定数として解決

2 箇所
URL 構築・初期値等

### 解決できない

27 箇所
Intent 同定は 0

**不明 27 ＝ Intent 由来 27 ではない。静的追跡の範囲外という結果。**

出典：卒論 §5.5 ・ §8.2

# 入力切替の仮説：要求先は何に従うか

実際の対照ランナーの仮説と観測基準を理解する。

| 仮説・比較 | A を入力 | B を入力 |
| --- | --- | --- |
| 入力端点へ依存 | A への要求が予想される | B への要求が予想される |
| 入力に非依存 | 固定先等の要求 | 同じ固定先等の要求 |
| 取得不十分・未観測 | 判別の根拠不足 | 仮説を強制的に除外しない |

**入力を変え、対象要求の端点が追随するかを確かめる。**

出典： research_diagnosis.py default_plan ・卒論 §3.11 ・ §8.3

# ABBA の 4 試行：入力と要求先が一致

入力切替の実測結果と、その限界を読む。

| 順番 | 入力 | 入力ポート | 観測ポート | HTTP |
|---|---|---|---|---|
| 1 | A | 59521 | 59521 | 200 |
| 2 | B | 59522 | 59522 | 200 |
| 3 | B | 59522 | 59522 | 200 |
| 4 | A | 59521 | 59521 | 200 |

**4/4 で入力端点へ追随。この操作条件での関連を実測で補強した。**

出典：卒論 表： URI 切替の補助事例

# 不明を捨てると、説明はどう変わるか

不明保持の設計を事後比較として理解する。

| 事後方式 | 扱い | 失う／残す情報 |
| --- | --- | --- |
| 不明保持 | 対象判定を保留 | 通信記録と帰属不足が残る |
| 不明行削除 | 評価材料から除外 | 未観測と誤解される余地 |
| UID 条件除去 | 宛先等だけで対象比較 | 対象帰属の裏付けが不足 |

**不明を保持すると、記録がある事実と判断不足を一緒に伝えられる。**

出典：卒論 §6.3 ・ §8.5 ・ §9.4

# 再現と品質：何を点検したのか

原本・ hash ・ partial ・統計差の関係を理解する。

### 再現

9 原本から
照合と対応表を再生成

### 根拠の点検

対象要求 6 件
前後対照 18 件

### 残る不確実性

統計差・帰属不明
品質 partial を保持

**再現できたこと、対象要求を確認したこと、完全性は別々に報告する。**

出典：卒論 §7.1–7.2 ・ §8.3 ・ §9.4

# 関連研究と、この研究の位置付け

新規性を過大に説明せず、具体的な焦点を述べる。

| 系統 | 代表例 | 本研究との関係 |
| --- | --- | --- |
| ポリシー整合 | PoliCheck / PurPliance / PoliGraph | 未指定・複数状態・根拠には先行例 |
| 差分通信 | Agrigento | 入力切替自体を新規とはしない |
| 操作・解析・取得 | DroidBot / MobSF / PCAPdroid | 既存機能を利用・区別して統括 |
| 本研究 | 事前 JSON ＋ APK ＋指定操作 | 具体的手順と参照条件での評価 |

**焦点は、開発者の構造化意図と証拠を結ぶ具体的な確認支援。**

出典：卒論 第 2 章（確認範囲は本文参照）

# 結論：できたことと、残っていること

卒論の着地点を自分の言葉で説明する。

| 確認したこと | 今回の範囲 |
| --- | --- |
| 実装と主評価 | 整合 3 、不一致 3 、保留 3 を再現 |
| 併用の意味 | 宣言・候補・実測を同時に読める |
| 評価の制約 | 自作素材・単一 AVD ・公開アプリ 1 本 |
| 次の仕上げ | 本文整合・独立確認・発表練習 |

**結論：参照条件で、設計した自己確認の規則が期待どおり動作した。**

出典：卒論 第 9–11 章・独立確認資料の現状

# 最後に： 5 問を説明できれば全体がつながる

理解した内容を自分の言葉で確認する。

| 確認する問い | 戻るスライド |
| --- | --- |
| なぜ意図を先に決める? | 3 ・ 7 ・ 8 |
| 動的のみは異常? | 16 ・ 23 ・ 24 |
| 遅延の結果は何? | 25 ・ 26 |
| 3/3 は精度 100% ? | 20 ・ 26 ・ 28 |
| 指摘の根拠はどこ? | 27 ・ 39 |

**暗記するのは件数よりも、「条件・証拠・結論」のつながり。**

出典：本学習資料の理解確認・卒論全体